МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РФ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ
УНИВЕРСИТЕТ» (ФГБОУ ВО «ВГТУ», ВГТУ)
Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности

ОТЧЁТ
по научно-исследовательской работе студента

Тема: «Разработка интеллектуальной системы оценки киберрисков серверной инфраструктуры Linux в условиях эксплуатации ошибок конфигурирования сервисов»

Разработал студент
гр. ИБ-211 «_____» Н.П. Перушкин
Подпись, дата Инициалы, фамилия

Руководитель: «_____»
Подпись, дата, должность, инициалы, фамилия

Защищен _____ Оценка _____
дата

Воронеж 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 3
1 Исследование аналогов и постановка задач работы в области проактивного управления рисками нарушения информационной безопасности серверной инфраструктуры Linux при эксплуатации ошибок конфигурирования сервисов 9
1.1 Исследование серверной инфраструктуры Linux как объекта защиты 9
1.2 Анализ ошибок конфигурирования сервисов и их взаимосвязи с известными уязвимостями 13
1.3 Построение дерева угроз и индуцированных ими рисков серверной инфраструктуры Linux 18
1.4 Анализ нормативно-правовых требований к конфигурированию сервисов 23
1.5 Сравнительный анализ средств проверки соответствия конфигураций и сканирования уязвимостей серверов 26
1.6 Изучение методов оценки критичности уязвимостей и вероятности их эксплуатации 27
1.7 Анализ методов построения графов атак с учётом уязвимостей и конфигурации 30
СПИСОК ЛИТЕРАТУРЫ 32

ВВЕДЕНИЕ

Операционные системы семейства Linux занимают доминирующее положение в серверном сегменте. По данным веб-технологического обзора W3Techs, на сентябрь 2026 года среди веб-серверов, для которых удаётся определить операционную систему, доля Unix-подобных систем составляет 92,1 %, а Linux – 62,5 % [1]. В российских условиях значимость этих систем усиливается курсом на импортозамещение: государственные информационные системы и значимые объекты критической информационной инфраструктуры переводятся на отечественные платформы, построенные на ядре Linux, что закреплено Указом Президента Российской Федерации от 30.03.2022 № 166 [2]. Наиболее распространённой из отечественных операционных систем этого класса называют Astra Linux [3]. Таким образом, защищённость всё большего числа информационных систем определяется тем, насколько корректно настроены системные и прикладные сервисы Linux.

Одновременно растёт число нацеленных на серверную инфраструктуру атак. Positive Technologies отмечает, что число атак в четвёртом квартале 2024 года выросло на 13 % по сравнению с аналогичным периодом предыдущего года [4]. При этом характер атак меняется: всё чаще нарушитель проникает в инфраструктуру не через сложный эксплойт, а через слабости периметра и учётных записей. По данным того же источника, в 44 % инцидентов точкой входа становились уязвимые веб-приложения на сетевом периметре, а доля атак через доверенные отношения с подрядчиками выросла до 15 % [5]. Масштаб ущерба тоже показателен: по оценке Экспертно-аналитического центра InfoWatch, за 2023–2025 годы в России утекло свыше 4,5 млрд записей персональных данных [6].

Существенную часть причин успешных атак составляют не только дефекты программного кода, но и ошибки конфигурирования сервисов. Показательны результаты мониторинга, проведённого компанией BI.ZONE: около 90 % организаций, использующих Linux, нарушают хотя бы одно требование методического документа ФСТЭК России по безопасной настройке, причём 48 % не

соблюдают четыре и более требований, и лишь 8 % выполняют их полностью [7]. Автор исследования прямо отмечает, что ошибки в настройках бывают столь же критичны, как и уязвимости в программном обеспечении, поскольку создают для нарушителя прямую точку входа [7]. Практические работы подтверждают этот тезис на конкретных примерах: в исследовании эксплуатации уязвимости BDU:2022-00488 (CVE-2021-4034) показано, как непривилегированный пользователь получает права суперпользователя на рабочей станции под управлением Debian и Astra Linux, после чего компрометирует ssh-ключи и закрепляется на удалённом сервере [3].

Ошибки конфигурирования и известные уязвимости программного кода на практике действуют совместно. Уязвимость, зарегистрированная в перечне CVE [8], базе NVD [9] и банке данных угроз ФСТЭК России [10], получает базовую оценку по системе CVSS [11, 12], которая описывает её свойства безотносительно к конкретной системе. Реальная же возможность её эксплуатации определяется настройками сервиса: один и тот же уязвимый пакет недостижим для нарушителя, если сервис слушает только локальный интерфейс и работает от непривилегированной учётной записи, и становится прямой точкой входа, если он открыт во внешнюю сеть без аутентификации. Для учёта таких обстоятельств спецификация CVSS 4.0 предусматривает метрики окружения [12], а вероятность эксплуатации уязвимости прогнозирует модель EPSS [13], однако заполнение метрик окружения по фактической конфигурации серверов остаётся ручной работой эксплуатирующей организации. Сами ошибки конфигурирования, как правило, не регистрируются в справочниках уязвимостей отдельными записями и описываются пунктами руководств по безопасной настройке.

Существующие средства анализа защищённости решают эти задачи порознь. Инструменты проверки соответствия профилю – OpenSCAP [14], Lynis [15], CIS-CAT [16], платформа Wazuh [17] – сравнивают фактические значения параметров с эталонными из руководств по безопасной настройке [18] и выдают двоичный вердикт «соответствует / не соответствует» по каждому параметру, а средства поиска известных уязвимостей, в том числе отечественный ScanOVAL [19], сопоставляют версии установленных пакетов с базой уязвимостей. Результат в

обоих случаях не содержит меры риска, не учитывает того, что конфигурация усиливает или ослабляет выявленную уязвимость, и не отражает того, что несколько отклонений и уязвимостей вместе образуют завершённую цепочку захвата узла. Кроме того, он отражает состояние системы лишь на момент проверки и устаревает при первом же изменении конфигурации.

Анализ публикаций показывает, что смежные с темой направления развиваются порознь. Риск-аналитический аппарат, развитый применительно к атакуемым сетям, эпидемическим процессам в них, картографии защищаемого киберпространства и организационно-правовой защите сетей [20–27], оперирует уязвимостями, у которых есть справочное описание и оценка критичности; работы по конфигурационным ошибкам заняты их обнаружением и классификацией; средства анализа защищённости выполняют проверку соответствия и инвентаризацию уязвимостей, а не риск-анализ. В итоге совместное влияние известных уязвимостей и ошибок конфигурирования на риск серверной инфраструктуры не получает единой количественной оценки, а меры защиты выбираются без сопоставления их вклада в снижение риска. Этим определяется актуальность работы, направленной на проактивный риск-анализ, то есть на оценку и регулирование риска до того, как уязвимости и ошибки конфигурирования будут эксплуатированы нарушителем.

Актуальность темы обусловлена следующими противоречиями:

– между существующим информационным обеспечением проектной деятельности по управлению рисками серверной инфраструктуры Linux и необходимостью его совершенствования в части покрытия потребностей проактивного риск-анализа при совместной эксплуатации известных уязвимостей и ошибок конфигурирования сервисов;

– между существующими методиками риск-анализа серверной инфраструктуры Linux и необходимостью их совершенствования в части учёта влияния конфигурации сервисов на критичность известных уязвимостей и оценки конфигурационных недостатков с использованием методов машинного обучения;

– между существующими методиками управления рисками нарушения информационной безопасности серверной инфраструктуры Linux и необходимостью их совершенствования в части проактивного регулирования риска с учётом альтернативных мер устранения уязвимостей и ошибок конфигурирования;

– между имеющимися средствами автоматизации оценки и регулирования рисков серверной инфраструктуры Linux и необходимостью их совершенствования для оценки эффективности предлагаемых технических решений в части проактивного экспресс-анализа процессов управления риском.

Объект исследования – серверная инфраструктура на базе операционных систем семейства Linux, включая системные и прикладные сервисы, их конфигурации, установленное программное обеспечение и обрабатываемые ими информационные активы.

Предмет исследования – модели, методики и алгоритмы проактивной оценки и регулирования рисков нарушения информационной безопасности серверной инфраструктуры Linux при совместной эксплуатации известных уязвимостей и ошибок конфигурирования сервисов.

Цель работы – повышение защищённости серверной инфраструктуры Linux от угроз, реализуемых через эксплуатацию ошибок конфигурирования сервисов и известных уязвимостей, за счёт разработки интеллектуальной системы проактивной оценки и регулирования соответствующих киберрисков.

Для достижения цели решаются следующие задачи:

– создать информационное обеспечение, покрывающее потребности проектной деятельности по проактивному управлению рисками нарушения информационной безопасности серверной инфраструктуры Linux с учётом взаимосвязи известных уязвимостей и ошибок конфигурирования сервисов;

– создать аналитическое обеспечение проактивной оценки риска нарушения информационной безопасности серверной инфраструктуры Linux, учитывающее контекст конфигурации при оценке известных уязвимостей и возможности предиктивных моделей машинного обучения при оценке конфигурационных недостатков;

– создать аналитическое обеспечение проактивного регулирования риска нарушения информационной безопасности серверной инфраструктуры Linux, учитывающее результаты оценки первичного риска и альтернативность мер – обновления программного обеспечения и компенсирующей перенастройки сервисов;

– сформировать средства автоматизации, ориентированные на проактивный экспресс-анализ процессов оценки и регулирования рисков нарушения информационной безопасности серверной инфраструктуры Linux, и оценить эффективность предлагаемых мер защиты.

Методы исследования. В работе применяются методы системного анализа и декомпозиции сложных систем, аппарат теории рисков, включая факторную модель анализа информационного риска FAIR [28], методы машинного обучения с учителем при прогнозировании критичности конфигурационных недостатков, а также методы объектно-ориентированного программирования при разработке программного обеспечения.

Результаты, выносимые на защиту, обладают следующей новизной:

– информационное обеспечение проактивного риск-анализа, которое, в отличие от аналогов, связывает известные уязвимости с конфигурационными недостатками, делающими их эксплуатируемыми, техниками MITRE ATT&CK и наступающим ущербом и формализует влияние параметров конфигурации сервисов на критичность уязвимостей;

– аналитическое обеспечение проактивной оценки риска, которое, в отличие от аналогов, переоценивает критичность известных уязвимостей по фактической конфигурации сервера на основе метрик окружения CVSS 4.0, прогнозирует критичность и вероятность эксплуатации конфигурационных недостатков моделью машинного обучения и объединяет обе оценки в графе атак для расчёта первичного риска по факторной модели FAIR;

– аналитическое обеспечение проактивного регулирования риска, которое, в отличие от аналогов, сопоставляет для узлов графа атак обновление программного обеспечения и компенсирующую перенастройку сервисов по величине снижения

риска и определяет очерёдность устранения уязвимостей и конфигурационных недостатков по их вкладу в сценарии атак;

– средства автоматизации, которые, в отличие от аналогов, выполняют полный цикл проактивного управления риском – от сбора снимка конфигурации и состава пакетов до количественной верификации эффективности выбранных мер – с пересчётом риск-ландшафта при изменении конфигурации.

Практическая ценность результатов состоит в следующем: структура и состав предложенного информационного обеспечения могут быть использованы при построении систем проактивного управления рисками серверной инфраструктуры Linux; методики риск-анализа позволяют получать количественную оценку первичного риска до эксплуатации уязвимостей и ошибок конфигурирования и ранжировать серверы и сервисы по его величине; аналитика регулирования риска поддерживает выбор мер защиты, в том числе при невозможности оперативного обновления программного обеспечения, и служит основой частных регламентов для системных администраторов; средства автоматизации избавляют от повторного ручного аудита при каждом изменении конфигурации и позволяют наблюдать динамику защищённости инфраструктуры во времени.

Теоретическая значимость состоит в том, что предложенные методики сбора и обработки данных могут быть развиты применительно к иным операционным системам и сетевому оборудованию; методики риск-анализа – в части учёта иных классов угроз, организационных и процедурных недостатков; аналитика регулирования риска – в части расширения состава учитываемых мер защиты и сценариев эксплуатации; созданный инструментарий допускает адаптацию для иных операционных систем и классов угроз.

1 Исследование аналогов и постановка задач работы в области проактивного управления рисками нарушения информационной безопасности серверной инфраструктуры Linux при эксплуатации ошибок конфигурирования сервисов

1.1 Исследование серверной инфраструктуры Linux как объекта защиты

Под серверной инфраструктурой здесь понимается совокупность вычислительных узлов под управлением операционных систем семейства Linux, установленных на них системных и прикладных сервисов и средств их взаимодействия, обеспечивающих обработку информации в интересах организации. Узел может быть физическим сервером, виртуальной машиной или экземпляром контейнерной среды; для риск-анализа важно не физическое воплощение узла, а набор его сервисов, состав установленного программного обеспечения и состояние их настроек.

Выбор Linux в качестве объекта исследования объясняется его преобладанием в серверном сегменте [1], открытостью кода и конфигурационных механизмов, которая допускает формализованный анализ настроек, и единообразием этих механизмов между дистрибутивами; отдельного внимания заслуживают отечественные дистрибутивы, применяемые в рамках импортозамещения [3]. Несмотря на различия в системах управления пакетами и наборах служб по умолчанию, подсистемы разграничения доступа, управления службами, регистрации событий и мандатного контроля [29] в современных дистрибутивах устроены на общих принципах [30]. Это позволяет строить модель объекта защиты, не привязанную к конкретному дистрибутиву.

Главная особенность такой инфраструктуры как объекта защиты в том, что её защищённость определяется не только применяемыми средствами защиты информации, но и состоянием настроек штатных механизмов ОС и сервисов. Один и тот же продукт одной и той же версии в зависимости от значений параметров может быть либо недоступен нарушителю, либо открывать ему прямой путь к данным, причём это относится и к известным уязвимостям продукта, их эксплуатируемость

также определяется настройками. Именно поэтому конфигурация становится самостоятельным предметом риск-анализа [31].

В составе инфраструктуры выделим восемь групп сервисов и механизмов, различающихся назначением и характером присущих им конфигурационных недостатков. Эта группировка положена в основу дальнейшей классификации и приведена в таблице 1.

Таблица 1 – Группы сервисов и механизмов серверной инфраструктуры Linux

Обозначение	**Группа**	**Состав и назначение**	**Контролируемые параметры**
G1	Сервисы удалённого доступа	Службы интерактивного управления узлом, прежде всего сервер защищённой оболочки [32]	Разрешение входа суперпользователя, способы аутентификации, криптоалгоритмы, ограничение попыток, перечень допущенных пользователей
G2	Идентификация и аутентификация	Подсистема подключаемых модулей [33], база учётных записей, политики паролей	Стойкость и срок действия пароля, блокировка после неудач, учётные записи с пустым паролем, многофакторное подтверждение
G3	Файловая система и права	Права на файлы и каталоги, специальные биты, повышение полномочий [34]	Права на файлы конфигурации, файлы с битом смены владельца, параметры монтирования, правила sudo
G4	Сетевые сервисы	Веб-серверы, СУБД, службы хранения, файловые службы	Интерфейсы прослушивания, обязательность аутентификации, шифрование канала, допущенные сети, анонимный доступ
G5	Механизмы изоляции	Мандатное разграничение [29], среды контейнеризации [35]	Режим мандатного контроля, привилегированный контейнер, монтирование каталогов узла, доступ к управляющему сокету
G6	Планировщики заданий	Служба периодических заданий, таймеры	Учётная запись выполнения задания, права на каталоги заданий, перечень допущенных пользователей
G7	Журналирование	Служба регистрации событий, системный журнал	Состав регистрируемых событий, централизованная передача, права на журналы, глубина хранения
G8	Управление пакетами	Подсистема установки и обновления ПО	Источники пакетов, проверка подписи, периодичность установки обновлений безопасности

Все перечисленные механизмы наблюдаемы непосредственно в самой операционной системе и не требуют внешних источников данных. Это важно для

автоматизации: снимок конфигурации узла и перечень установленных пакетов с их версиями снимаются штатными средствами, без установки дополнительного ПО на защищаемый узел.

Введём обозначения для последующей формализации. Пусть N – множество узлов инфраструктуры, S – множество развёрнутых на них сервисов, причём каждому узлу n сопоставлено подмножество сервисов S(n) и множество известных уязвимостей V(n), выявляемых по версиям установленных пакетов. Каждый сервис s описывается набором конфигурационных параметров, значения которых в момент времени t образуют вектор конфигурации c(s, t). Совокупность таких векторов по всем сервисам даёт снимок конфигурации C(t). Через A обозначим множество защищаемых активов, через R(n, a) – отношение достижимости актива a с узла n. Мера риска инфраструктуры вычисляется на основе снимка C(t), множеств уязвимостей V(n), множества активов A и отношения достижимости.

Связь субъектов доступа, сервисов и защищаемых активов образует модель объекта защиты, представленную на рисунке 1.

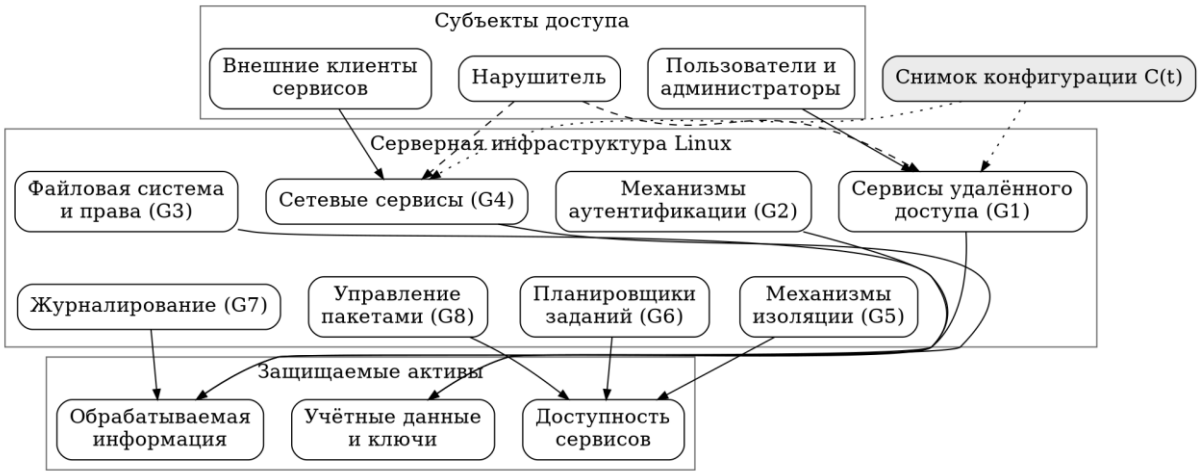


Рисунок 1 – Модель серверной инфраструктуры Linux как объекта защиты

Модель показывает, что сервисы стоят между субъектами доступа и активами, а конфигурация задаёт условия, при которых доступ разрешается или блокируется. Нарушитель, не располагающий средством эксплуатации уязвимости, работает с инфраструктурой через те же штатные механизмы, что и легитимный пользователь,

и успех его действий целиком определяется значениями параметров [3]. Если же такое средство у него есть, конфигурация определяет, доступен ли ему уязвимый сервис и какие полномочия он получит в случае успеха.

Защищаемые активы неоднородны по последствиям нарушения их безопасности. Первая категория – обрабатываемая информация: персональные данные, коммерческая тайна, технологические сведения; нарушение их конфиденциальности или целостности даёт прямой и правовой ущерб. Вторая – учётные данные и криптографические ключи на узлах; их компрометация не наносит ущерба сама по себе, но открывает путь к остальным активам и обеспечивает перемещение внутри периметра [3]. Третья – доступность сервисов, нарушение которой ведёт к простою системы и связанным с ним потерям.

Обстоятельства, определяющие риск эксплуатации ошибки конфигурирования или уязвимости, наблюдаемы и измеримы. К ним относятся:

– атрибуты доступности – интерфейсы прослушивания, наличие сетевой фильтрации, достижимость сервиса извне;

– атрибуты аутентификации – обязательность подтверждения личности, применяемый способ, стойкость допускаемых паролей;

– атрибуты полномочий – учётная запись, от имени которой работает сервис, объём её прав, наличие правил безусловного повышения полномочий;

– атрибуты изоляции – режим мандатного контроля, параметры запуска контейнеров, ограничения на системные вызовы;

– атрибуты наблюдаемости – состав регистрируемых событий, централизованное хранение журналов, возможность восстановить ход инцидента;

– атрибуты состава программного обеспечения – перечень установленных пакетов и их версии, по которым определяются известные уязвимости узла;

– атрибуты значимости – категории достижимых с узла активов, участие узла в обработке персональных данных или в составе значимого объекта КИИ.

Эти свойства образуют признаковое пространство узла и сервиса, в котором в третьей главе решаются задачи количественной оценки критичности уязвимостей и конфигурационных недостатков.

1.2 Анализ ошибок конфигурирования сервисов и их взаимосвязи с известными уязвимостями

По ГОСТ Р 56546 уязвимость информационной системы определяется как её недостаток, использование которого нарушителем способно привести к реализации угрозы безопасности информации [36]. Приведённая в стандарте классификация выделяет уязвимости по области происхождения, и наряду с уязвимостями кода в самостоятельные классы отнесены уязвимости конфигурации, архитектуры и организационные. То есть отечественная нормативная база признаёт конфигурационный недостаток разновидностью уязвимости, хотя справочники уязвимостей ведутся прежде всего по уязвимостям кода, привязанным к версиям продуктов.

В международной терминологии конфигурационные недостатки отражены перечнем типов слабостей CWE [37]: небезопасное значение по умолчанию, некорректное назначение прав, применение встроенных учётных данных и другие. Перечень описывает типы слабостей, а не конкретные экземпляры в конкретных системах, и не содержит количественных оценок.

Определим ошибку конфигурирования сервиса как значение конфигурационного параметра, допустимое с точки зрения разработчика и не являющееся дефектом кода, но в условиях эксплуатации порождающее состояние, использование которого нарушителем ведёт к реализации угрозы. Из этого определения вытекает ряд особенностей, важных для методики риск-анализа.

Во-первых, ошибка конфигурирования не привязана к версии продукта. Уязвимость кода существует в конкретных версиях и закрывается обновлением; конфигурационный недостаток воспроизводится в любой версии, потому что его причина – выбранное значение параметра, а не реализация. Отсюда и другой способ устранения: не обновление, а изменение параметра, что не несёт риска несовместимости, но требует понимания функциональных последствий [31].

Во-вторых, такой недостаток, как правило, не получает собственного идентификатора. Присвоение CVE предполагает дефект в конкретном продукте

конкретного производителя [8], а состояние, возникшее из-за выбора администратором допустимого значения, под это условие не подпадает, поэтому недостаток описывается пунктом руководства по настройке и типом слабости CWE. Исключение составляют небезопасные значения по умолчанию, заложенные самим производителем: они регистрируются как уязвимости продукта и получают записи в NVD [9] и банке данных угроз ФСТЭК России [10] вместе с оценкой CVSS и прогнозом EPSS [13]. Этот класс записей служит естественным мостом между уязвимостями кода и ошибками конфигурирования.

В-третьих, у ошибки конфигурирования иной жизненный цикл. Уязвимость кода появляется с выпуском версии и исчезает с установкой обновления, то есть является внешним для организации событием. Конфигурационный недостаток возникает при развёртывании или изменении настроек, то есть порождается действиями самой организации, и может вернуться после отката конфигурации, восстановления из резервной копии или ручной правки. Постепенное расхождение фактической конфигурации с утверждённой – конфигурационный дрейф – исследовано в работах по эксплуатации программных систем [38, 39] и является одной из главных причин устаревания разового обследования.

В-четвёртых, ответственность за появление недостатка во многом лежит не на квалификации администратора, а на проектных решениях разработчика. Значительная доля ошибок вызвана небезопасными значениями по умолчанию и сложностью самих конфигурационных механизмов [38]. Для риск-регулирования это существенно: организационные меры, адресованные только администратору, без автоматизированного контроля настроек оказываются недостаточными [7].

Сопоставление уязвимости кода и ошибки конфигурирования по признакам, важным для риск-анализа, приведено в таблице 2.

Таблица 2 – Сопоставление уязвимости программного кода и ошибки конфигурирования

Признак	**Уязвимость программного кода**	**Ошибка конфигурирования**
Причина	Дефект реализации продукта	Значение параметра, выбранное при развёртывании или эксплуатации
Идентификатор	CVE, запись в NVD и банке данных угроз	Как правило, собственного нет: пункт руководства по настройке и тип слабости CWE
Количественная оценка	Базовый вектор CVSS, прогноз EPSS	Двоичный вердикт проверки; оценка CVSS – только для небезопасных значений по умолчанию, зарегистрированных как уязвимости
Зависимость от версии	Есть в конкретных версиях	Воспроизводится в любой версии
Влияние конфигурации	Эксплуатируемость и последствия зависят от настроек сервиса	Сама является состоянием конфигурации
Способ устранения	Установка обновления или компенсирующая настройка	Изменение значения параметра
Способ обнаружения	Сверка версии с базой уязвимостей	Сверка значений параметров с эталонным профилем
Повторное появление	Исключено после обновления	Возможно из-за конфигурационного дрейфа
Источник сведений	CVE, NVD, банк данных угроз	CIS Benchmarks, DISA STIG, SCAP, CWE

Различия, приведённые в таблице 2, не означают, что уязвимости кода и ошибки конфигурирования следует анализировать раздельно. На практике они тесно связаны, и эта связь проявляется в четырёх формах.

Первая форма – конфигурация открывает доступ к уязвимости. Уязвимость сервиса эксплуатируема только тогда, когда сервис достижим для нарушителя. Так, уязвимость CVE-2022-0543 в пакетах Redis для Debian и Ubuntu позволяет выйти из песочницы интерпретатора Lua и выполнить произвольный код [9], и она включена в каталог эксплуатируемых уязвимостей CISA [40]. Эксплуатировать её может лишь тот, кто способен отправить службе команду, поэтому решающее значение имеют интерфейс прослушивания и обязательность аутентификации – параметры группы G4.

Вторая форма – конфигурация определяет последствия эксплуатации. Успешная атака на сервис даёт нарушителю полномочия той учётной записи, от

имени которой сервис работает. При работе от суперпользователя или в привилегированном контейнере последствия той же уязвимости намного тяжелее, чем при работе от выделенной непривилегированной учётной записи в среде, ограниченной мандатным контролем [29, 35].

Третья форма – ошибка конфигурирования и уязвимость образуют звенья одной цепочки. Уязвимость локального повышения привилегий, например CVE-2021-4034 в компоненте pkexec [3] или CVE-2021-3156 в sudo [9], опасна для узла, на котором у нарушителя уже есть непривилегированный доступ, а такой доступ ему часто даёт именно ошибка конфигурирования – парольная аутентификация без ограничения попыток или учётная запись с пустым паролем. И наоборот, уязвимость сетевого сервиса даёт вход, а правило безусловного повышения полномочий [34] или задание планировщика с избыточными правами – права суперпользователя.

Четвёртая форма – конфигурация служит компенсирующей мерой. Если обновление недоступно или его установка требует остановки сервиса, эксплуатацию уязвимости нередко можно исключить или затруднить настройкой: ограничить интерфейс прослушивания, отключить уязвимый модуль, включить мандатный контроль. Характерный пример – уязвимость CVE-2024-6387 в сервере OpenSSH, для которой в качестве временной меры рекомендовалось изменить значение параметра LoginGraceTime [9, 32]. Применение компенсирующих мер при невозможности обновления предусмотрено и руководством ФСТЭК России по организации процесса управления уязвимостями [41].

Формы взаимосвязи сведены в таблицу 3.

Таблица 3 – Формы взаимосвязи известных уязвимостей и ошибок конфигурирования

Форма взаимосвязи	**Пример**	**Следствие для риск-анализа**
Конфигурация открывает доступ к уязвимости	CVE-2022-0543 в Redis при доступности службы со всех интерфейсов без аутентификации	Базовая оценка CVSS должна уточняться по фактической достижимости сервиса
Конфигурация определяет последствия	Уязвимость сервиса, работающего от суперпользователя или в привилегированном контейнере	Ущерб зависит от полномочий учётной записи сервиса и режима изоляции
Звенья одной цепочки	Подбор пароля при неограниченном числе попыток входа и CVE-2021-4034 для повышения привилегий	Риск определяется сценарием, а не отдельным недостатком
Компенсирующая настройка	CVE-2024-6387 в OpenSSH и изменение параметра LoginGraceTime	Для уязвимости существует альтернатива обновлению

Из сказанного следует, что ошибка конфигурирования – полноценный источник риска и одновременно фактор, определяющий риск известных уязвимостей. Существующий аппарат использует идентификатор уязвимости как ключ, по которому доступны оценка критичности и статистика эксплуатации, но эта оценка описывает уязвимость вне конкретной системы, а конфигурационный недостаток без собственного идентификатора учитывается лишь двоичным признаком соответствия. Для проактивного риск-анализа обе сущности нужно рассматривать совместно – в единой базе соответствий и на едином графе атак.

Практическую значимость этого вывода подтверждает статистика. Мониторинг BI.ZONE показал, что около 90 % организаций с Linux-инфраструктурой нарушают хотя бы одно требование методики ФСТЭК России, а почти половина – четыре и более [7]. Positive Technologies отмечает, что в 44 % инцидентов точкой входа служил уязвимый периметр [5], а исследование эксплуатации BDU:2022-00488 демонстрирует, как из сочетания уязвимости и конфигурационных предпосылок разворачивается полная цепочка компрометации узла [3]. Получается, что самый распространённый на практике класс недостатков

хуже всего обеспечен аппаратом количественной оценки, а его влияние на риск известных уязвимостей остаётся неучтённым.

1.3 Построение дерева угроз и индуцированных ими рисков серверной инфраструктуры Linux

Результаты анализа объекта защиты и источников риска позволяют построить дерево угроз и индуцированных ими рисков. Методические рекомендации предписывают строить такое дерево в первой главе и делать его основой всего дальнейшего исследования, обеспечивая полноту охвата угроз; фрагментарный анализ методика прямо запрещает [42].

Недостатки классифицируются по двум независимым основаниям. Первое – группа сервисов (таблица 1), оно отражает структуру объекта защиты. Второе – механизм возникновения опасного состояния, оно определяет характер риска и способ устранения. По второму основанию выделяются:

– недостатки доступности – служба открыта более широкому кругу, чем нужно (доступность со всех интерфейсов, отсутствие ограничения по сетям);

– недостатки аутентификации – подтверждение личности не требуется, идёт по пустым или предустановленным данным либо допускает неограниченный подбор;

– недостатки разграничения полномочий – субъекту или сервису дано больше прав, чем необходимо (работа от суперпользователя, безусловное повышение полномочий);

– недостатки изоляции – механизмы ограничения среды отключены или ослаблены (отключённый мандатный контроль, привилегированный контейнер);

– недостатки криптографической защиты – передача или хранение без шифрования либо с устаревшими алгоритмами;

– недостатки наблюдаемости – регистрация событий не ведётся, ведётся неполно или журналы не защищены;

– недостатки доверия к источникам – устанавливаемое ПО не проверяется на подлинность или берётся из недоверенных источников.

Известные уязвимости сервисов распределяются по тем же классам по достигаемому результату эксплуатации: уязвимость, дающая удалённое выполнение кода в сетевом сервисе, относится к той же ветви, что и доступность службы без аутентификации, а уязвимость локального повышения привилегий – к ветви разграничения полномочий. Классификация задумана как разбиение: каждый недостаток относится ровно к одному классу по второму основанию и к одной группе по первому, что позволяет в дальнейшем агрегировать оценки риска по группам и классам.

Системообразующая угроза для рассматриваемого объекта – эксплуатация ошибок конфигурирования сервисов серверной инфраструктуры Linux, в том числе в сочетании с известными уязвимостями установленного программного обеспечения. Её источники: внешний нарушитель без полномочий, внешний нарушитель с действительными учётными данными, внутренний нарушитель из числа пользователей или администраторов, а также нарушитель через цепочку поставки ПО и конфигураций. Категории нарушителей и их возможности определяются по методике оценки угроз [43].

Риски, индуцированные этой угрозой, делятся на четыре группы – технические, информационные, экономические и правовые. Верхний уровень дерева угроз показан на рисунке 2.

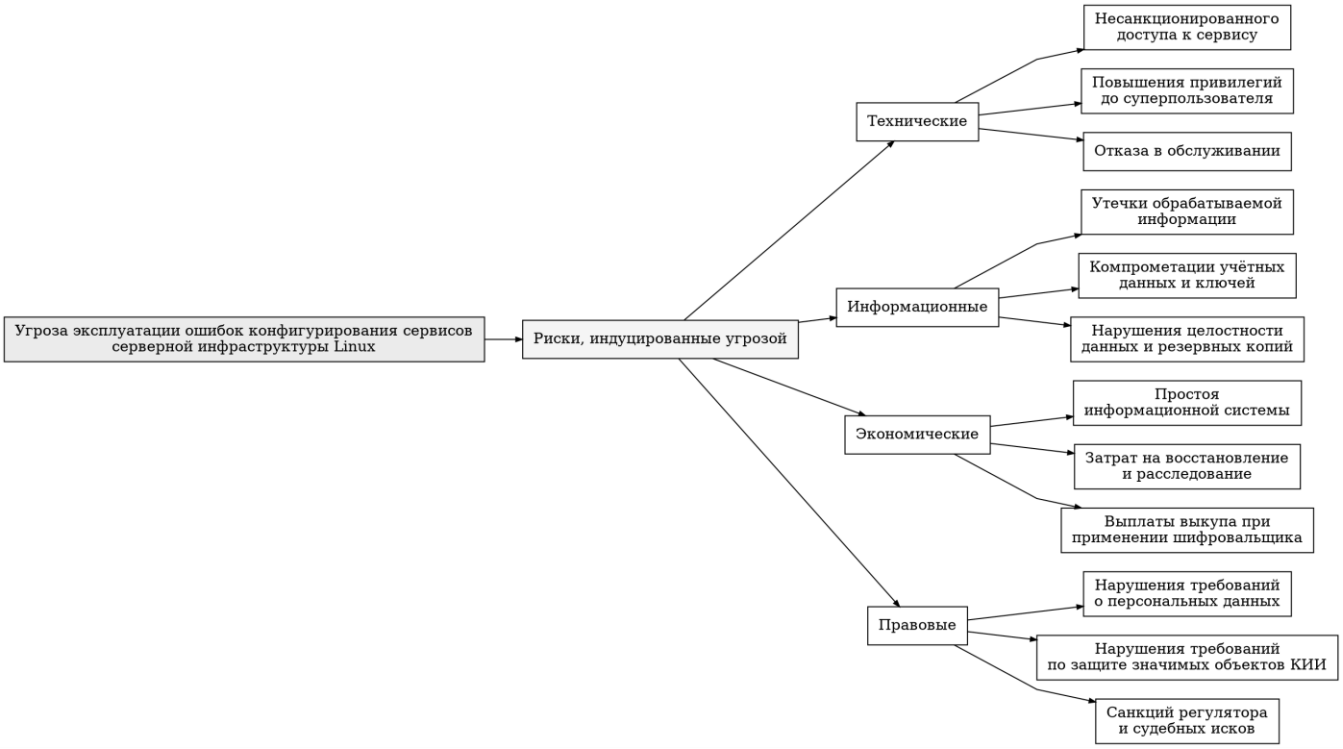


Рисунок 2 – Дерево угроз и индуцированных ими рисков серверной инфраструктуры Linux

Технические риски отражают последствия для самой инфраструктуры: несанкционированный доступ к сервису, повышение полномочий до суперпользователя, закрепление, перемещение внутри периметра, нарушение работоспособности. Информационные – последствия для данных: утечка информации ограниченного доступа, компрометация учётных данных и ключей, нарушение целостности данных и резервных копий; масштаб таких утечек в стране подтверждается статистикой InfoWatch [6]. Экономические – простой системы, затраты на восстановление и расследование, выплата выкупа при шифровальщике. Правовые – нарушение требований законодательства о персональных данных [44] и о безопасности КИИ [45, 46], а также санкции по итогам проверок регулятора.

Дальше дерево детализируется по группам сервисов. Фрагменты для первых четырёх и последующих четырёх групп приведены на рисунках 3 и 4.

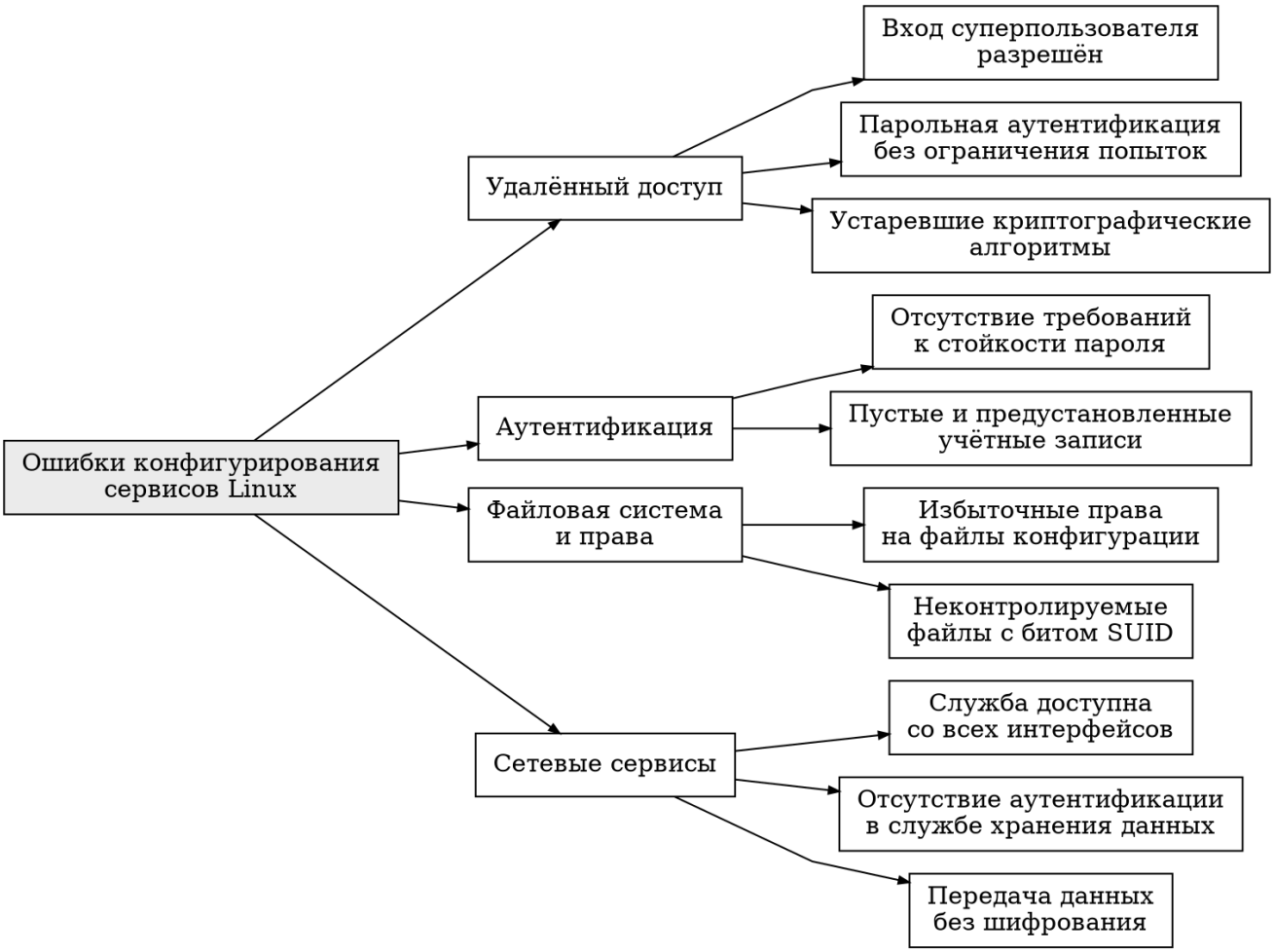


Рисунок 3 – Фрагмент дерева угроз: удалённый доступ, аутентификация, файловая система, сетевые сервисы

Листья дерева соответствуют конкретным конфигурационным недостаткам и классам известных уязвимостей групп сервисов. Во второй главе каждому листу будут сопоставлены записи базы соответствий, в третьей – мера риска отдельного недостатка или уязвимости, а узлам верхних уровней – агрегированная мера риска группы. Тем самым дерево служит не иллюстрацией, а структурой данных для всей дальнейшей работы.



Рисунок 4 – Фрагмент дерева угроз: изоляция, планировщики, журналирование, управление пакетами

Отдельно стоит вопрос связности. Дерево показывает принадлежность недостатка к группе, но не отражает того, что эксплуатация одного недостатка открывает путь к следующему. Например, доступная со всех интерфейсов служба хранения данных даёт нарушителю точку входа, отсутствие в ней аутентификации – содержимое, найденные в нём учётные данные – вход через сервер защищённой оболочки, а правило безусловного повышения полномочий или незакрытая уязвимость локального повышения привилегий – права суперпользователя. Несколько недостатков, каждый из которых по отдельности можно счесть некритичным, вместе образуют полную цепочку захвата узла – что и подтверждают практические разборы атак [3]. Методы формализации таких цепочек рассматриваются в подразделе 1.7.

1.4 Анализ нормативно-правовых требований к конфигурированию сервисов

Требования к защите информации в серверной инфраструктуре задаёт совокупность нормативных актов и методических документов. Основу отечественного регулирования образуют федеральные законы об информации [47], о персональных данных [44] и о безопасности критической информационной инфраструктуры [45]. Курс на переход КИИ и госсектора на отечественные решения закреплён Указом Президента [2]. Базовые термины определены ГОСТ Р 50922 [48].

Состав и содержание мер защиты установлены приказами ФСТЭК России – для государственных информационных систем [49], информационных систем персональных данных [50] и значимых объектов КИИ [46]. Порядок определения актуальных угроз, включая модель нарушителя и сценарии реализации угроз, задан методикой оценки угроз [43], а конкретные требования к настройке Linux – методическим документом ФСТЭК России по безопасной настройке [51]. Именно последний документ прямо связывает нормативные требования с конфигурационными параметрами и потому особенно важен для темы работы.

Меры, относящиеся к предмету исследования, сосредоточены в группах по идентификации и аутентификации, управлению доступом, ограничению программной среды, регистрации событий, обеспечению целостности и защите среды виртуализации. Их содержание и отражение в конфигурации сервисов Linux приведены в таблице 4 (обобщение по требованиям приказов ФСТЭК и рекомендациям по безопасной настройке [7, 49, 51]).

Таблица 4 – Меры защиты информации и их отражение в конфигурации сервисов Linux

Группа мер	Содержание требования	Отражение в конфигурации	Группа сервисов
Идентификация и аутентификация	Управление идентификаторами и средствами аутентификации, правила паролей	Стойкость и срок пароля, блокировка после неудач, запрет пустых паролей	G2
Управление доступом	Управление учётными записями, разграничение прав, ограничение попыток входа	Запрет входа суперпользователя, правила sudo, права на файлы, допущенные сети	G1, G3, G4
Ограничение программной среды	Управление запуском ПО, установка и обновление разрешённого ПО	Проверка подписи пакетов, доверенные источники, ограничение запуска исполняемых файлов	G8
Регистрация событий	Состав регистрируемых событий, сбор, хранение и защита журналов	Правила регистрации, централизованная передача, права на журналы, глубина хранения	G7
Обеспечение целостности	Контроль целостности ПО и информации	Контроль неизменности файлов конфигурации и исполняемых файлов	G3, G8
Защита среды виртуализации	Разграничение доступа к компонентам виртуальной инфраструктуры	Режим мандатного контроля, параметры запуска контейнеров, доступ к сокету	G5
Защита каналов	Защита каналов передачи и интерфейсов управления	Шифрование канала, ограничение интерфейсов прослушивания, криптоалгоритмы	G1, G4

Легко заметить, что требования формулируются в терминах наличия или отсутствия меры. Требование об управлении доступом предписывает разграничивать права, но не говорит, во сколько раз возрастает риск при правиле безусловного повышения полномочий для конкретной учётной записи и насколько этот риск отличается от риска доступной со всех интерфейсов службы хранения данных. Результат проверки – двоичный вердикт, а сопоставления узлов по величине риска нормативные документы не предусматривают. При ограниченном ресурсе администратора это лишает обоснованного порядка устранения недостатков [7].

Для известных уязвимостей отечественная база в последние годы дополнена документами, прямо относящимися к их обработке. Методика оценки уровня критичности уязвимостей программных, программно-аппаратных средств [52]

предписывает определять приоритет устранения уязвимости с учётом не только её базовой оценки CVSS, но и характеристик конкретной информационной системы, а руководство по организации процесса управления уязвимостями [41] задаёт порядок их выявления, оценки, устранения, в том числе с применением компенсирующих мер, и контроля устранения. Эти документы ориентированы на уязвимости, выявляемые по перечню установленного программного обеспечения и записям банка данных угроз, тогда как требования к настройке сформулированы отдельно [51], и связь между ними эксплуатирующая организация устанавливает самостоятельно.

Требования к менеджменту риска вынесены в отдельную группу документов. Общие принципы заданы ГОСТ Р ИСО 31000 [53], применительно к ИБ – ГОСТ Р ИСО/МЭК 27005 [54]. Эти документы задают процессную рамку управления риском, но не дают методики вычисления меры риска для конкретного конфигурационного недостатка или уязвимости в конкретной конфигурации.

Зарубежная база устроена похоже. Руководство по общей безопасности серверов [55] содержит рекомендации по безопасной настройке, а методика оценки риска [56] задаёт общий порядок её проведения. Наиболее детальные требования к значениям параметров содержатся в руководствах по безопасной настройке CIS Benchmarks [18] и DISA STIG [57], причём последние снабжают каждое требование одной из трёх категорий важности. На эти руководства опираются средства проверки соответствия, рассматриваемые в следующем подразделе.

Итог подраздела: нормативное обеспечение задаёт требуемый состав мер, требуемые значения отдельных параметров и порядок обработки известных уязвимостей, но не даёт средств количественно сопоставить конфигурационные недостатки и уязвимости по величине индуцируемого риска с учётом их взаимного влияния.

1.5 Сравнительный анализ средств проверки соответствия конфигураций и сканирования уязвимостей серверов

Выявлением конфигурационных недостатков и известных уязвимостей занимаются два класса программных средств, и их сравнительный анализ нужен, чтобы очертить границы существующих возможностей.

Средства проверки соответствия профилю сверяют фактические значения параметров с эталонными. OpenSCAP [14] – открытая реализация протокола автоматизации SCAP [58], выполняющая проверки по машиночитаемому контенту на языке OVAL; тот же механизм позволяет ей проверять узел и на известные уязвимости по OVAL-описаниям производителей дистрибутивов. Аудитор Lynis [15] выполняет набор встроенных проверок настроек и выдаёт рекомендации по усилению защиты вместе с интегральным индексом защищённости. Инструмент CIS-CAT [16] оценивает соответствие узла руководствам CIS Benchmarks, выпускаемым отдельно под каждый дистрибутив [59], и выражает результат долей выполненных требований. Платформа Wazuh [17] объединяет модуль оценки конфигурации безопасности с модулем обнаружения уязвимостей по перечню установленных пакетов.

Средства поиска известных уязвимостей сопоставляют версии установленного программного обеспечения с базами уязвимостей. Отечественный ScanOVAL [19] выполняет такое сопоставление по OVAL-описаниям банка данных угроз ФСТЭК России [10]. Сетевые сканеры и системы управления уязвимостями – Nessus [60] и отечественный MaxPatrol VM [61] – выполняют инвентаризацию активов и поиск известных уязвимостей, дополняя его ограниченным набором конфигурационных проверок и приоритизацией уязвимостей по собственным рейтингам. Отдельно стоят средства статического анализа описаний инфраструктуры как кода, контроля поведения во время исполнения и автоматизации конфигурирования, применяемые для приведения настроек к утверждённому состоянию.

Сопоставление средств по критериям, существенным для проактивного риск-анализа, приведено в таблице 5.

Таблица 5 – Сравнение средств проверки конфигураций и поиска уязвимостей серверов

Средство	Проверка конфигурации	Поиск известных уязвимостей	Оценка риска	Учёт цепочек атак
OpenSCAP	По SCAP-контенту	По OVAL-описаниям	Не выполняется, вердикт по правилу	Нет
Lynis	Встроенные проверки	Ограниченно	Интегральный индекс защищённости	Нет
CIS-CAT	По CIS Benchmarks	Нет	Доля выполненных требований	Нет
ScanOVAL	Нет	По банку данных угроз ФСТЭК России	Уровень опасности уязвимости	Нет
Wazuh	Модуль оценки конфигурации	По перечню пакетов	Уровень опасности уязвимости или события	Нет
Nessus	Ограниченно	Да	Рейтинг уязвимости	Нет
MaxPatrol VM	Ограниченно	Да	Приоритет уязвимости	Нет

Анализ показывает, что проверка конфигурации и поиск известных уязвимостей выполняются либо разными средствами, либо разными модулями одного средства, и их результаты не сводятся в единую оценку: уязвимость оценивается без учёта того, как настроен уязвимый сервис, а отклонение от профиля – без учёта того, какие уязвимости оно делает эксплуатируемыми. Ни одно из рассмотренных средств не рассчитывает меру риска как произведение ущерба на вероятность его наступления и не рассматривает цепочки, в которых чередуются уязвимости и ошибки конфигурирования. Результат проверки отражает состояние на момент сканирования, а выбор между обновлением программного обеспечения и перенастройкой сервиса остаётся за администратором.

1.6 Изучение методов оценки критичности уязвимостей и вероятности их эксплуатации

Для количественного риск-анализа нужны две величины – возможный ущерб и вероятность его наступления; мера риска в методологии, развиваемой в работах по теории сетевых войн [20–27], определяется их произведением. Рассмотрим, какие

существующие методы дают оценки этих величин для уязвимостей и в какой мере они применимы к ошибкам конфигурирования.

Наиболее распространена система оценки CVSS. В версии 3.1 [11] она включает базовые, временные и контекстные метрики, однако справочники публикуют, как правило, только базовую оценку, описывающую уязвимость вне конкретной системы. Версия 4.0 [12] пересмотрела состав метрик: временная группа заменена группой угрозы с метрикой зрелости средств эксплуатации, а группа окружения позволяет переопределить базовые метрики – вектор атаки, сложность, требуемые привилегии, последствия для конфиденциальности, целостности и доступности – по фактическим условиям и задать требования к защищённости актива. Именно метрики окружения формально описывают влияние конфигурации на критичность уязвимости: сервис, слушающий только локальный интерфейс, меняет сетевой вектор атаки на локальный, а обязательная аутентификация повышает требуемые привилегии. Спецификация, однако, не устанавливает, как выводить значения этих метрик из настроек сервисов, и их заполнение остаётся экспертной работой.

Вероятность эксплуатации оценивается иначе. Модель EPSS [13] прогнозирует вероятность того, что уязвимость будет эксплуатироваться в ближайшие 30 дней, по признакам из её описания и наблюдаемой активности нарушителей. Каталог эксплуатируемых уязвимостей CISA KEV [40] фиксирует факт эксплуатации в реальных атаках. Отечественная методика оценки уровня критичности уязвимостей [52] дополняет оценку CVSS характеристиками конкретной информационной системы. Все эти оценки ведутся по идентификатору уязвимости: у конфигурационного недостатка, не имеющего собственной записи, нет ни прогноза EPSS, ни отметки в каталоге, и вероятность его эксплуатации приходится оценивать иначе – например, прогнозировать по уязвимостям тех же типов слабостей CWE, для которых такие оценки известны.

Для перехода от критичности к риску применяются методы количественного анализа риска. Факторная модель FAIR [28] раскладывает риск на частоту событий потерь и величину потерь; частота событий потерь, в свою очередь, определяется

частотой угрозы и уязвимостью актива, понимаемой как вероятность того, что действие угрозы приведёт к потере. Модель даёт риск в денежном выражении и допускает статистическое моделирование методом Монте-Карло, но исходные значения для конкретного технического недостатка в ней оцениваются экспертно. Стандарты менеджмента риска [53, 54] и методика оценки риска NIST [56] задают процессную рамку и качественные шкалы, а методика оценки угроз ФСТЭК России [43] – порядок определения актуальных угроз без вычисления меры риска.

Сопоставление методов приведено в таблице 6.

Таблица 6 – Методы оценки критичности уязвимостей и риска

Метод	**Что оценивает**	**Входные данные**	**Применимость к ошибкам конфигурирования**
CVSS 3.1	Критичность уязвимости	Вектор базовых метрик из справочника	Только для зарегистрированных уязвимостей
CVSS 4.0	Критичность с учётом угрозы и окружения	Базовые метрики, зрелость средств эксплуатации, метрики окружения	Метрики окружения описывают влияние конфигурации, правила их вывода из настроек не заданы
EPSS	Вероятность эксплуатации в течение 30 дней	Идентификатор CVE и признаки уязвимости	Только для уязвимостей с идентификатором CVE
CISA KEV	Факт эксплуатации в реальных атаках	Идентификатор CVE	Только для уязвимостей с идентификатором CVE
Методика ФСТЭК России	Уровень критичности уязвимости для конкретной системы	Оценка CVSS и характеристики системы	Для уязвимостей из банка данных угроз
FAIR	Риск в денежном выражении	Частота угрозы, уязвимость актива, величина потерь	Применима при наличии оценок частоты и вероятности
ГОСТ Р ИСО/МЭК 27005, NIST SP 800-30	Уровень риска по качественным шкалам	Экспертные оценки	Применимы без количественной меры

Таким образом, существующие методы позволяют оценить критичность и вероятность эксплуатации известной уязвимости, а модель FAIR – перевести эти оценки в риск. Однако связь метрик окружения CVSS 4.0 с конкретными

настройками сервисов не формализована, а для ошибок конфигурирования без собственной записи отсутствуют исходные оценки вероятности эксплуатации.

1.7 Анализ методов построения графов атак с учётом уязвимостей и конфигурации

Оценки отдельных уязвимостей и недостатков не отражают того, что нарушитель достигает цели последовательностью действий. Для описания таких последовательностей применяются деревья и графы атак.

Дерево атак [62] описывает цель нарушителя корнем, а способы её достижения – ветвями с логическими связками «И» и «ИЛИ»; значения вероятности или стоимости атаки, заданные в листьях, агрегируются к корню. Этот формализм близок к дереву угроз из подраздела 1.3, но строится для одной цели и не отражает состояния конкретной инфраструктуры.

Граф атак описывает инфраструктуру как множество состояний, переходы между которыми соответствуют действиям нарушителя. В работе [63] граф атак строится автоматически методом проверки моделей по описанию сети, уязвимостей узлов и возможностей нарушителя; недостатком подхода стал быстрый рост числа состояний с увеличением размера сети. Логический анализатор MulVAL [64] снимает эту проблему, представляя граф в виде логических правил: на вход подаются результаты сканирования уязвимостей в формате OVAL, сведения о сетевой достижимости и о конфигурации узлов – какие сервисы от имени каких учётных записей работают, – а на выходе получается граф, узлы которого соответствуют фактам и выводимым из них привилегиям нарушителя. Тем самым MulVAL уже соединяет уязвимости и конфигурацию, но конфигурация учитывается в нём как фиксированный набор фактов о сервисах и сетевом доступе, а не как множество проверяемых параметров, каждый из которых может оказаться ошибкой. Метрики защищённости сети, вычисляемые на графах атак [65], позволяют агрегировать вероятности отдельных шагов в вероятность достижения цели.

Для привязки шагов графа к реальным действиям нарушителя служат базы знаний MITRE. Классификация шаблонов атак CAPEC [66] описывает обобщённые способы нападения и связывает их с типами слабостей CWE, а матрица MITRE ATT&CK [67] – конкретные техники, наблюдаемые в реальных атаках. Отношение «недостаток – техника» многозначно: одному недостатку обычно соответствует несколько техник, а одна техника достижима через разные недостатки и уязвимости.

Применительно к теме работы это означает, что аппарат графов атак пригоден для совместного учёта уязвимостей и ошибок конфигурирования, если узлы-недостатки получат количественные оценки, сопоставимые с оценками уязвимостей, а переходы – привязку к техникам ATT&CK. Тогда сценарий эксплуатации определяется как путь в графе, связывающий исходное положение нарушителя с защищаемым активом [64], а риск сценария – через вероятности его шагов и ущерб от достижения актива.

СПИСОК ЛИТЕРАТУРЫ

1. Usage statistics and market share of Linux for websites : статистика использования операционных систем на веб-серверах / W3Techs, Q-Success. – URL: https://w3techs.com/technologies/details/os-linux (дата обращения: 13.09.2026). – Текст : электронный.

2. О мерах по обеспечению технологической независимости и безопасности критической информационной инфраструктуры Российской Федерации : Указ Президента Российской Федерации от 30.03.2022 № 166. – Доступ из справ.-правовой системы «КонсультантПлюс» (дата обращения: 13.09.2026). – Текст : электронный.

3. Степанова Е. А. Эксплуатация уязвимости операционной системы Astra Linux / Е. А. Степанова, Д. А. Елизаров, Е. Е. Мурзалева // Прикаспийский журнал: управление и высокие технологии. – 2025. – № 1 (69). – С. 86–90. – Текст : непосредственный.

4. Актуальные киберугрозы: IV квартал 2024 года – I квартал 2025 года : аналитический отчёт / Positive Technologies // CISOCLUB. – 2025. – URL: https://cisoclub.ru/aktualnye-kiberugrozy-iv-kvartal-2024-goda-i-kvartal-2025-goda/ (дата обращения: 12.09.2026). – Текст : электронный.

5. Positive Technologies назвала тренды кибератак уходящего года // CNews. – 2024. – URL: https://safe.cnews.ru/news/line/2024-12-26_positive_technologies_nazvala_trendy (дата обращения: 12.09.2026). – Текст : электронный.

6. За три года в России утекло 4,5 млрд записей персональных данных : по данным Экспертно-аналитического центра InfoWatch // CISOCLUB. – 2026. – URL: https://cisoclub.ru/model-ugroz-bezopasnosti-informacii/ (дата обращения: 12.09.2026). – Текст : электронный.

7. Русин М. Как обеспечить безопасность ОС Linux по рекомендациям ФСТЭК России / М. Русин ; BI.ZONE // Хабр. – 2025. – URL:

https://habr.com/ru/companies/bizone/articles/950982/ (дата обращения: 12.09.2026). – Текст : электронный.

8. CVE Program : common vulnerabilities and exposures / The MITRE Corporation. – URL: https://www.cve.org (дата обращения: 12.09.2026). – Текст : электронный.

9. National Vulnerability Database / National Institute of Standards and Technology. – URL: https://nvd.nist.gov (дата обращения: 12.09.2026). – Текст : электронный.

10. Банк данных угроз безопасности информации / ФСТЭК России, ГНИИИ ПТЗИ ФСТЭК России. – URL: https://bdu.fstec.ru (дата обращения: 12.09.2026). – Текст : электронный.

11. Common Vulnerability Scoring System v3.1 : Specification Document / Forum of Incident Response and Security Teams. – FIRST.Org, 2019. – URL: https://www.first.org/cvss/v3-1/specification-document (дата обращения: 12.09.2026). – Текст : электронный.

12. Common Vulnerability Scoring System version 4.0 : Specification Document / Forum of Incident Response and Security Teams. – FIRST.Org, 2023. – URL: https://www.first.org/cvss/v4-0/specification-document (дата обращения: 12.09.2026). – Текст : электронный.

13. Exploit Prediction Scoring System (EPSS) : model documentation / Forum of Incident Response and Security Teams. – URL: https://www.first.org/epss (дата обращения: 12.09.2026). – Текст : электронный.

14. OpenSCAP : open source security compliance solution. – URL: https://www.open-scap.org (дата обращения: 12.09.2026). – Текст : электронный.

15. Lynis : security auditing tool for Linux, macOS and UNIX-based systems / CISOfy. – URL: https://cisofy.com/lynis/ (дата обращения: 12.09.2026). – Текст : электронный.

16. CIS-CAT Pro Assessor : configuration assessment tool / Center for Internet Security. – URL: https://www.cisecurity.org/cybersecurity-tools/cis-cat-pro/ (дата обращения: 12.09.2026). – Текст : электронный.

17. Wazuh : the open source security platform. Documentation. – URL: https://documentation.wazuh.com (дата обращения: 12.09.2026). – Текст : электронный.

18. CIS Benchmarks : secure configuration guidelines / Center for Internet Security. – URL: https://www.cisecurity.org/cis-benchmarks (дата обращения: 12.09.2026). – Текст : электронный.

19. ScanOVAL для Astra Linux : средство анализа защищённости от известных уязвимостей / ФСТЭК России. – URL: https://bdu.fstec.ru/site/scanoval (дата обращения: 12.09.2026). – Текст : электронный.

20. Эпидемии в телекоммуникационных сетях / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2017. – 284 с. – (Теория сетевых войн ; вып. 1). – Текст : непосредственный.

21. Атакуемые взвешенные сети / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2017. – 284 с. – (Теория сетевых войн ; вып. 2). – Текст : непосредственный.

22. Социальные сети и деструктивный контент / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2017. – 284 с. – (Теория сетевых войн ; вып. 3). – Текст : непосредственный.

23. Социальные сети и риск-мониторинг / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2019. – 284 с. – (Теория сетевых войн ; вып. 4). – Текст : непосредственный.

24. Социальные сети и психологическая безопасность / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2020. – 284 с. – (Теория сетевых войн ; вып. 5). – Текст : непосредственный.

25. Сетео-информационная эпидемиология / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2021. – 284 с. – (Теория сетевых войн ; вып. 6). – Текст : непосредственный.

26. Картография защищаемого киберпространства / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2022. – 372 с. – (Теория сетевых войн ; вып. 7). – Текст : непосредственный.

27. Организационно-правовая защита сетей / А. Г. Остапенко [и др.] ; под редакцией чл.-корр. РАН Д. А. Новикова. – Москва : Горячая линия – Телеком, 2023. – 228 с. – (Теория сетевых войн ; вып. 8). – Текст : непосредственный.

28. Freund J. Measuring and Managing Information Risk: A FAIR Approach / J. Freund, J. Jones. – Oxford : Butterworth-Heinemann, 2015. – 408 p. – Текст : непосредственный.

29. SELinux User's and Administrator's Guide / Red Hat, Inc. – URL: https://access.redhat.com/documentation/ (дата обращения: 12.09.2026). – Текст : электронный.

30. Лиманова Н. И. Основные механизмы безопасности в Linux / Н. И. Лиманова, А. С. Анашкин // Бюллетень науки и практики. – 2024. – Т. 10, № 2. – С. 404–406. – DOI 10.33619/2414-2948/99/39. – Текст : непосредственный.

31. Двенадцать советов по повышению безопасности Linux : пер. с англ. / RUVDS // Хабр. – 2017. – URL: https://habr.com/ru/companies/ruvds/articles/343892/ (дата обращения: 12.09.2026). – Текст : электронный.

32. OpenSSH : sshd_config manual page / OpenBSD Project. – URL: https://man.openbsd.org/sshd_config (дата обращения: 12.09.2026). – Текст : электронный.

33. Linux-PAM : System Administrators' Guide. – URL: https://man7.org/linux/man-pages/man8/pam.8.html (дата обращения: 12.09.2026). – Текст : электронный.

34. sudoers(5): Sudo manual / T. C. Miller. – URL: https://www.sudo.ws/docs/man/sudoers.man/ (дата обращения: 12.09.2026). – Текст : электронный.

35. Docker Engine security : documentation / Docker, Inc. – URL: https://docs.docker.com/engine/security/ (дата обращения: 12.09.2026). – Текст : электронный.

36. ГОСТ Р 56546–2015. Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем. – Москва : Стандартинформ, 2015. – 12 с. – Текст : непосредственный.

37. Common Weakness Enumeration : перечень типов слабостей программного и аппаратного обеспечения / The MITRE Corporation. – URL: https://cwe.mitre.org (дата обращения: 12.09.2026). – Текст : электронный.

38. Yin Z. An empirical study on configuration errors in commercial and open source systems / Z. Yin, X. Ma, J. Zheng [et al.] // Proceedings of the 23rd ACM Symposium on Operating Systems Principles. – Cascais : ACM, 2011. – P. 159–172. – Текст : непосредственный.

39. Xu T. Systems approaches to tackling configuration errors: a survey / T. Xu, Y. Zhou // ACM Computing Surveys. – 2015. – Vol. 47, No. 4. – Art. 70. – 41 p. – Текст : непосредственный.

40. Known Exploited Vulnerabilities Catalog : каталог эксплуатируемых уязвимостей / Cybersecurity and Infrastructure Security Agency. – URL: https://www.cisa.gov/known-exploited-vulnerabilities-catalog (дата обращения: 12.09.2026). – Текст : электронный.

41. Руководство по организации процесса управления уязвимостями в органе (организации) : методический документ : утверждён ФСТЭК России 17.05.2023. – Москва : ФСТЭК России, 2023. – Текст : непосредственный.

42. Краткие научно-методические рекомендации по формированию и выполнению технических заданий в области обеспечения информационной безопасности / А. Г. Остапенко, М. Е. Волкова, Д. А. Нархов [и др.] // Информация и безопасность. – 2020. – Т. 23, вып. 4. – С. 551–560. – Текст : непосредственный.

43. Методика оценки угроз безопасности информации : методический документ : утверждён ФСТЭК России 05.02.2021. – Москва : ФСТЭК России, 2021. – 83 с. – Текст : непосредственный.

44. О персональных данных : Федеральный закон от 27.07.2006 № 152-ФЗ. – Доступ из справ.-правовой системы «КонсультантПлюс» (дата обращения: 13.09.2026). – Текст : электронный.

45. О безопасности критической информационной инфраструктуры Российской Федерации : Федеральный закон от 26.07.2017 № 187-ФЗ. – Доступ из

справ.-правовой системы «КонсультантПлюс» (дата обращения: 13.09.2026). – Текст : электронный.

46. Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации : приказ ФСТЭК России от 25.12.2017 № 239. – Доступ из справ.-правовой системы «КонсультантПлюс» (дата обращения: 13.09.2026). – Текст : электронный.

47. Об информации, информационных технологиях и о защите информации : Федеральный закон от 27.07.2006 № 149-ФЗ. – Доступ из справ.-правовой системы «КонсультантПлюс» (дата обращения: 13.09.2026). – Текст : электронный.

48. ГОСТ Р 50922–2006. Защита информации. Основные термины и определения. – Москва : Стандартинформ, 2008. – 12 с. – Текст : непосредственный.

49. Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах : приказ ФСТЭК России от 11.02.2013 № 17. – Доступ из справ.-правовой системы «КонсультантПлюс» (дата обращения: 13.09.2026). – Текст : электронный.

50. Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных : приказ ФСТЭК России от 18.02.2013 № 21. – Доступ из справ.-правовой системы «КонсультантПлюс» (дата обращения: 13.09.2026). – Текст : электронный.

51. Рекомендации по безопасной настройке операционных систем Linux : методический документ : утверждён ФСТЭК России 25.12.2022. – Москва : ФСТЭК России, 2022. – Текст : непосредственный.

52. Методика оценки уровня критичности уязвимостей программных, программно-аппаратных средств : методический документ : утверждён ФСТЭК России 28.10.2022. – Москва : ФСТЭК России, 2022. – Текст : непосредственный.

53. ГОСТ Р ИСО 31000–2019. Менеджмент риска. Принципы и руководство. – Москва : Стандартинформ, 2020. – 20 с. – Текст : непосредственный.

54. ГОСТ Р ИСО/МЭК 27005–2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. – Москва : Стандартинформ, 2011. – 51 с. – Текст : непосредственный.

55. Scarfone K. Guide to General Server Security : NIST Special Publication 800-123 / K. Scarfone, W. Jansen, M. Tracy. – Gaithersburg : NIST, 2008. – 53 p. – Текст : непосредственный.

56. Guide for Conducting Risk Assessments : NIST Special Publication 800-30 Rev. 1 / Joint Task Force Transformation Initiative. – Gaithersburg : NIST, 2012. – 95 p. – Текст : непосредственный.

57. Security Technical Implementation Guides / Defense Information Systems Agency. – URL: https://public.cyber.mil/stigs (дата обращения: 12.09.2026). – Текст : электронный.

58. Waltermire D. The Technical Specification for the Security Content Automation Protocol (SCAP) : NIST Special Publication 800-126 Rev. 3 / D. Waltermire, S. Quinn, H. Booth [et al.]. – Gaithersburg : NIST, 2018. – 62 p. – Текст : непосредственный.

59. CIS Ubuntu Linux 22.04 LTS Benchmark : v2.0.0 / Center for Internet Security. – East Greenbush, 2024. – URL: https://www.cisecurity.org/benchmark/ubuntu_linux (дата обращения: 12.09.2026). – Текст : электронный.

60. Nessus : vulnerability assessment solution / Tenable, Inc. – URL: https://www.tenable.com/products/nessus (дата обращения: 12.09.2026). – Текст : электронный.

61. MaxPatrol VM : система управления уязвимостями / Positive Technologies. – URL: https://www.ptsecurity.com/ru-ru/products/mpvm/ (дата обращения: 12.09.2026). – Текст : электронный.

62. Schneier B. Attack trees / B. Schneier // Dr. Dobb's Journal. – 1999. – Vol. 24, No. 12. – P. 21–29. – Текст : непосредственный.

63. Sheyner O. Automated generation and analysis of attack graphs / O. Sheyner, J. Haines, S. Jha [et al.] // Proceedings 2002 IEEE Symposium on Security and Privacy. – Berkeley : IEEE, 2002. – P. 273–284. – Текст : непосредственный.

64. Ou X. MulVAL: a logic-based network security analyzer / X. Ou, S. Govindavajhala, A. W. Appel // Proceedings of the 14th USENIX Security Symposium. – Baltimore, 2005. – P. 113–128. – Текст : непосредственный.

65. Wang L. Network Security Metrics / L. Wang, S. Jajodia, A. Singhal. – Cham : Springer, 2017. – 207 p. – Текст : непосредственный.

66. Common Attack Pattern Enumeration and Classification / The MITRE Corporation. – URL: https://capec.mitre.org (дата обращения: 12.09.2026). – Текст : электронный.

67. MITRE ATT&CK : база знаний тактик и техник нарушителя / The MITRE Corporation. – URL: https://attack.mitre.org (дата обращения: 12.09.2026). – Текст : электронный.